

REPORTE DE PENETRATION TESTING

Meridian Lab — Evaluación de Seguridad de RedInterna

Cliente	Meridian Lab
Ejecutado por	Ernesto Cruz Manjarrez
Fecha de ejecución	03 agosto 2026
Fecha del reporte	09 agosto 2026
Clasificación	Confidencial — Uso interno exclusivo
Versión	1.0

Tabla de Contenidos

1. Resumen Ejecutivo	3
2. Alcance y Reglas de Engagement	3
3. Metodología	3
4. Inteligencia y Reconocimiento (OSINT)	3
5. Modelado de Amenazas	4
6. Análisis de Vulnerabilidades	4
7. Explotación	5
8. Post-Explotación	5
9. Hallazgos Técnicos Detallados	6
10. Matriz de Riesgo	6
11. Recomendaciones y Remediación	6
12. Anexos	6

1. Resumen Ejecutivo

Entre el 03 y 06 de agosto de 2026, se realizó una evaluación de penetration testing sobre la infraestructura interna de Meridian Lab, con el objetivo de identificar debilidades explotables que pudieran comprometer la confidencialidad, integridad y disponibilidad de los datos de la empresa.

Se identificaron **2 hallazgo crítico y 1 medios**. Los vectores de mayor riesgo son una inyección SQL en el formulario de login del portal, que permite bypass total de autenticación y acceso directo a la base de datos, y una vulnerabilidad de carga de archivos sin restricción en el plugin de WordPress de Marketing, que permitió la ejecución remota de comandos en el servidor. Adicionalmente, se identificó una vulnerabilidad de control de acceso (IDOR) en el portal que expuso registros del staff de servicios a usuarios no autorizados. La combinación de estos hallazgos representa compromiso total de la aplicación y del servidor subyacente.

Se recomienda remediación inmediata de los hallazgos críticos antes de 15 días hábiles.

2. Alcance y Reglas de Engagement

Campo	Detalle
Activos en alcance	10.60.6.20, 10.60.6.30, 10.60.6.40
Fuera de alcance	Infraestructura de terceros
Tipo de prueba	Caja gris (credenciales de bajo privilegio proporcionadas para fase interna)
Ventana autorizada	03–06 agosto 2026, 08:00–20:00 hora local
Contacto de emergencia	Luis Noel Lopez Vazquez
Autorización	Carta de autorización firmada, referencia #PT-2026-014

3. Metodología

Esta evaluación siguió el estándar PTES (Penetration Testing Execution Standard), complementado con técnicas del marco C|PENT de EC-Council:

```
Pre-engagement → Intelligence Gathering → Threat Modeling → Vulnerability Analysis →  
Exploitation → Post-Exploitation → Reporting
```

Todas las pruebas se realizaron minimizando el impacto en la disponibilidad de los sistemas en producción.

4. Inteligencia y Reconocimiento (OSINT)

Objetivo de la fase: construir un perfil del objetivo sin interacción directa/activa con sus sistemas.

Hallazgos relevantes

- Portal – Portal.meridian.local

- WordPress – cms.meridian.local
- API – shop.meridian.local

5. Modelado de Amenazas

Objetivo de la fase: priorizar rutas de ataque en base al perfil de riesgo conocido de cada tecnología, sin datos de OSINT por tratarse de un entorno de CTF con scope cerrado.

Activo crítico	Superficie de ataque probable	Justificación	Confianza	Prioridad
Portal Portal.meridian.local	Fallas de autorización (IDOR), fuga de datos en respuestas, inyección (command, code, sql, etc).	Sitio web interno, probablemente sin autenticación o controles débiles.	Media	1
WordPress cms.meridian.local 10.60.6.30	Enumeración de plugins, temas, usuarios, CVEs conocidos, fuerza bruta de login, archivos de configuración expuestos, inyección (command, code, sql, etc).	CMS identificado explícitamente por nombre; historial extenso de vulnerabilidades públicas y malas configuraciones comunes.	Alta	2

Rutas de ataque priorizadas para la siguiente fase

- portal.meridian.local
- cms.meridian.local
- shop.meridian.local

6. Análisis de Vulnerabilidades

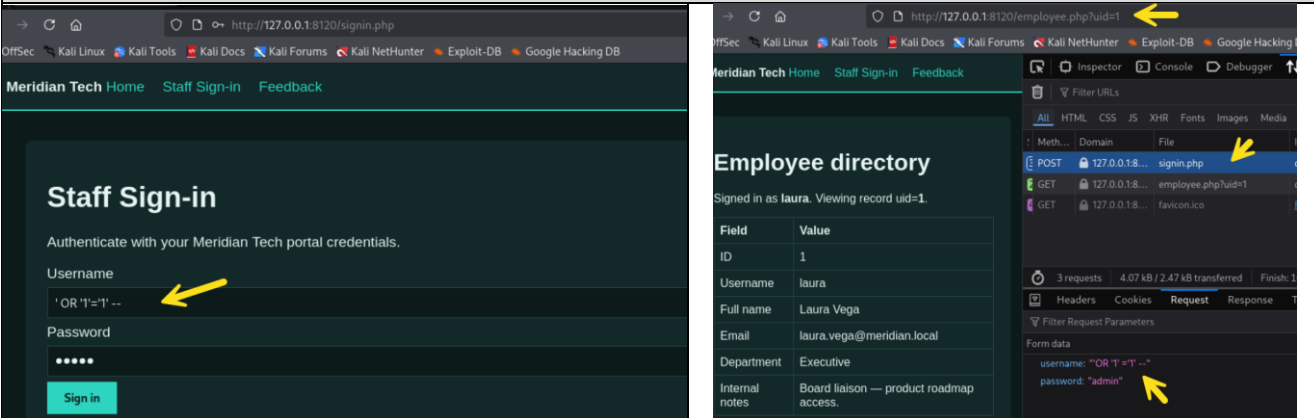
Objetivo de la fase: confirmar técnicamente, mediante herramientas y validación manual, las debilidades sugeridas por el modelado de amenazas.

#	Activo	Herramienta	Hallazgo	Validación Manual
V-01	Portal.meridian.local	nmap, whatweb, gobuster, prueba manual de parámetros	Inyección SQL en Login	Sí
V-02	Portal.meridian.local	Prueba manual de parámetros	IDOR en Sitio Web	Sí
V-03	cms.meridian.local	nmap, wpscan, gobuster, pruebas manuales	Plugin de Carga de Archivos -> Ejecución remota de código	Sí

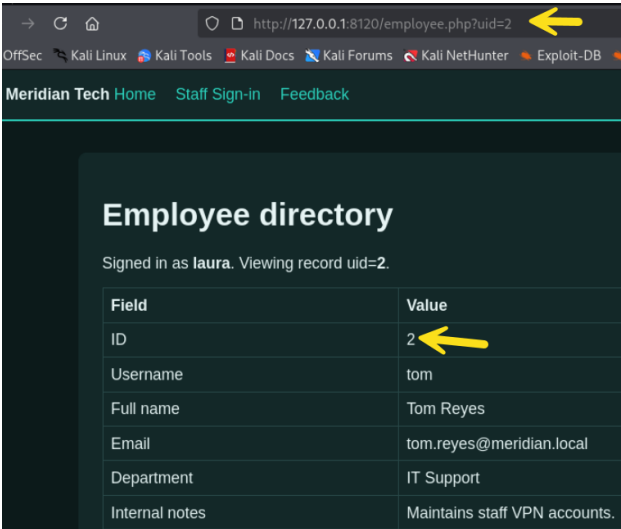
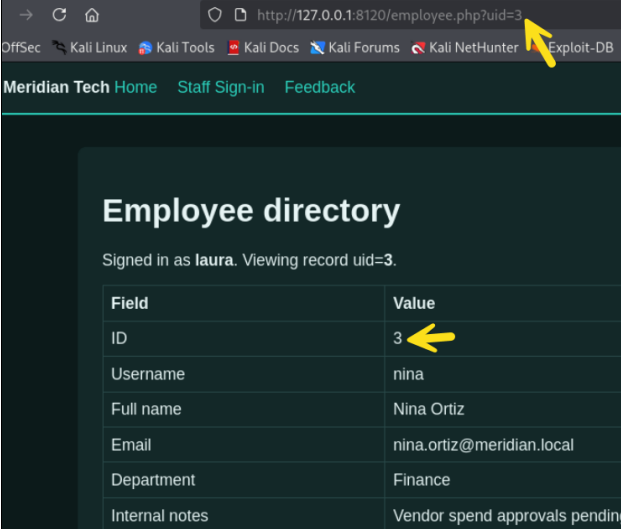
7. Explotación

Objetivo de la fase: demostrar de forma controlada y reproducible que la vulnerabilidad es explotable, evitando daño colateral.

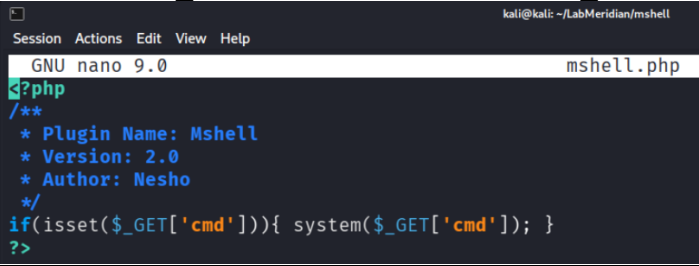
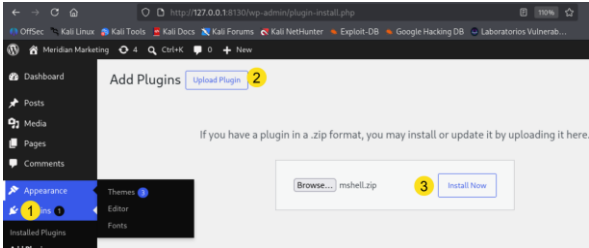
V-01 — Inyección sql en Portal.meridian.local

Comando / Resultado
' OR '1'='1' --
Evidencia 

V-02 — IDOR en Portal.meridian.local

Comando / Resultado	
<pre>http://127.0.0.1:8120/employee.php?uid=2 http://127.0.0.1:8120/employee.php?uid=3</pre>	
Evidencia	
	

V-03 — Plugin vulnerable de carga de archivos en cms.meridian.local

Comando / Resultado	
<pre>if(isset(\$_GET['cmd'])){ system(\$_GET['cmd']); }</pre>	
Evidencia	
	

8. Post-Explotación

Objetivo de la fase: determinar el impacto real y el alcance del acceso obtenido ("blast radius"), no solo confirmar que hubo acceso.

- Mediante el uso de Sqli se pudo ingresar al portal.
- Mediante el uso de credenciales y password por default se pudo ingresar como administrador al WP
- A través del plugin vulnerable fue posible la ejecución de un comando de forma remota (RCE)

9. Hallazgos Técnicos Detallados

Nivel de Riesgo	Activo	Vulnerabilidad	Impacto Técnico
Crítico (9.3) CVE-2026-2584	portal.meridian.local	Inyección SQL en Login	Acceso a BD, ejecución de comandos en el SO, bypass total de autenticación
Alto (7.5) CVE-2026-13369	cms.meridian.local	Plugin de Carga de Archivos Ejecución remota de comandos	Lectura no autorizada de archivos del sistema (/etc/passwd, archivos de configuración)
Medio CWE-862	portal.meridian.local	IDOR / IDOR en Sitio Web	Lectura/modificación de registros específicos cambiando parámetros (IDs)

10. Matriz de Riesgo

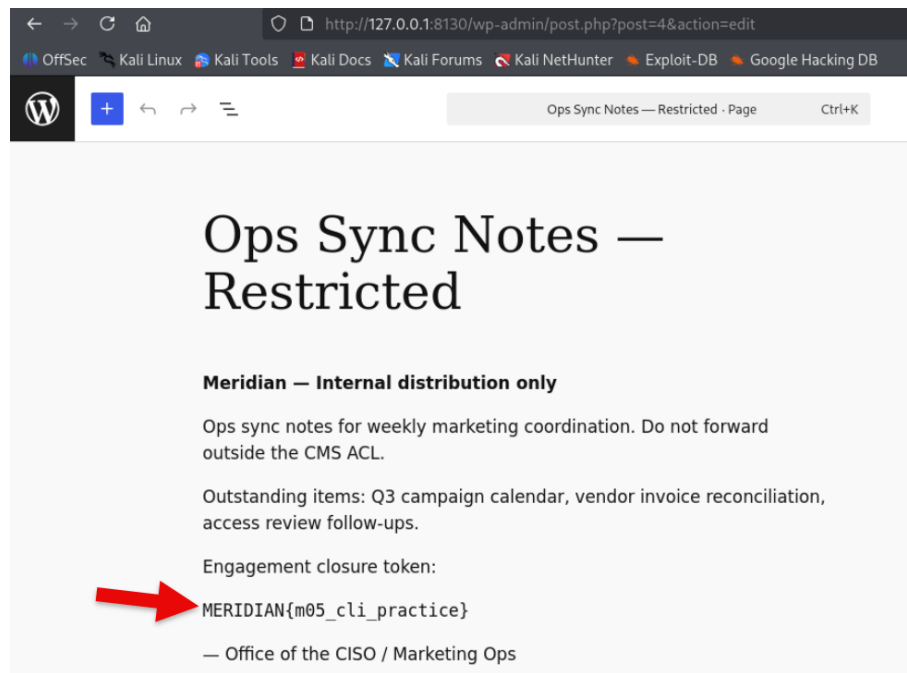
Hallazgo	Severidad	Probabilidad	Riesgo Final
V-01 Inyección SQL en Login	Crítica	Alta	Crítico
V-02 IDOR en sitio web	Alta	Media	Alto
V-03 Plugin vulnerable	Media	Alta	Alto

11. Recomendaciones y Remediación

Prioridad	Acción	Plazo sugerido
1	Aplicar sanitización a los campos de "Username" y "Password" del login para impedir el ingreso de caracteres especiales (metacaracteres) utilizados en ataques de inyección.	Inmediato (≤5 días)
2	Actualizar/parchar Wordpress para eliminar la vulnerabilidad del plugin	15 días

Prioridad	Acción	Plazo sugerido
3	Aplicar controles para la autorización una vez que se completa la autenticación	15 días

Obtención de la flag



reporte. Documento confidencial — distribución restringida a personal autorizado de Meridian Labs.